

Modelos e Técnicas Computacionais para Análise de Requisitos de Segurança (Safety e Security)

Prof. Rodrigo Martins Pagliares — Unifal

Valor: 10 pontos (peso 0.4)	Data: ____/____/____
Nome: _____	Turma: _____

Instruções: Leia com atenção. Assinale uma única alternativa por questão. Preencha o gabarito abaixo antes de entregar.

1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20
___	___	___	___	___	___	___	___	___	___	___	___	___	___	___	___	___	___	___	___

1. [SWEBOK — Fundamentos]

De acordo com o SWEBOK, qual das afirmações abaixo descreve **CORRETAMENTE** a atividade de elicitação de requisitos?

- a) É a atividade responsável por formalizar e documentar os requisitos já analisados, produzindo o documento SRS.
- b) Consiste na investigação inicial para identificar requisitos candidatos, minimizando incompletude por meio de técnicas como entrevistas, workshops e prototipagem.
- c) Corresponde à verificação de que os requisitos levantados atendem às necessidades reais dos stakeholders, sendo realizada apenas no final do ciclo de vida.
- d) É sinônimo de validação de requisitos e ocorre exclusivamente em projetos que adotam modelo de ciclo de vida em cascata.
- e) Tem como único objetivo a resolução de conflitos entre requisitos concorrentes de diferentes stakeholders.

2. [SWEBOK — Categorias de Requisitos]

Ao utilizar o "filtro da tecnologia perfeita", um analista conclui que, mesmo com hardware ilimitado, o sistema de gestão hospitalar ainda precisaria especificar que "um médico não pode prescrever medicamento sem CRM ativo". Que tipo de requisito é esse e por quê?

- a) Requisito não funcional de segurança, pois envolve controle de acesso.
- b) Requisito funcional, pois descreve uma regra de negócio que independe da tecnologia utilizada.
- c) Requisito de projeto, pois impõe uma restrição ao escopo e ao prazo de entrega.
- d) Requisito de qualidade de serviço, pois impacta a disponibilidade do sistema.
- e) Requisito derivado, pois não foi solicitado diretamente por nenhum stakeholder.

3. [SWEBOK — Análise e Qualidade]

Durante a análise de requisitos, a equipe percebe que dois requisitos entram em conflito: o setor de marketing quer que o relatório seja gerado em tempo real, enquanto o setor de TI argumenta que isso inviabilizaria a infraestrutura atual. Que atividade do processo de engenharia de requisitos deve tratar essa situação?

- a) Elicitação, pois novos stakeholders devem ser entrevistados para desempatar a decisão.
- b) Especificação, pois o conflito deve ser documentado no SRS sem resolução.
- c) Resolução de conflitos (parte da análise), que pode envolver negociação entre stakeholders e, quando cabível, técnicas como Product Family Development.
- d) Validação, pois o conflito só pode ser resolvido após a implementação do protótipo.
- e) Scrubbing, pois ambos os requisitos devem ser eliminados por serem conflitantes.

4. [SWEBOK — Especificação / BDD]

Um analista escreve o seguinte critério de aceitação: *"Dado que o saldo em conta é R\$200, quando o cliente solicita saque de R\$300, então o caixa não deve liberar o dinheiro e deve exibir mensagem de saldo insuficiente."* Qual técnica de especificação de requisitos está sendo utilizada?

- a) Linguagem natural não estruturada, com sentença no formato "o sistema deverá".
- b) Especificação formal com linguagem Z, permitindo prova matemática da corretude.
- c) Behavior Driven Development (BDD) com sintaxe Gherkin (Given / When / Then).
- d) Diagrama de caso de uso UML, representando o fluxo alternativo de um cenário.
- e) Test-Driven Development (TDD) de nível unitário, testando um método isolado.

5. [SWEBOK — Gestão / Rastreabilidade]

Uma empresa descobre que, ao alterar o requisito RF-042 ("o sistema deve emitir nota fiscal eletrônica"), seis casos de uso, três classes de domínio e doze casos de teste serão impactados. Qual conceito de gestão de requisitos é fundamental para identificar esse impacto com precisão?

- a) Requirements scrubbing, que elimina requisitos desnecessários antes da validação.
- b) Scope matching, que verifica se o escopo cabe dentro das restrições de custo e prazo.
- c) Rastreabilidade de requisitos (forward e backward), que permite navegar das especificações até os artefatos de design, código e teste.
- d) Priorização de requisitos pelo modelo Kano, que ranqueia itens pelo valor ao cliente.
- e) Especificação incremental, que documenta apenas as diferenças entre versões.

6. [SWEBOK — Validação]

A analogia "construir certo a coisa" versus "construir a coisa certa" é clássica na área de engenharia de software. Qual par de atividades ela representa, respectivamente?

- a) Elicitação e especificação.
- b) Análise e gestão de requisitos.
- c) Verificação e validação.
- d) Scrubbing e controle de alterações.
- e) Prototipagem e rastreabilidade.

7. [Engenharia de Sistemas — Propriedades Emergentes]

Um projetista afirma: "posso garantir a segurança do sistema simplesmente somando os requisitos de segurança de cada componente individualmente". Por que essa afirmação está INCORRETA?

- a) Porque a segurança é um requisito funcional e deve ser especificada no SRS, não nos componentes.
- b) Porque safety e security são propriedades emergentes: só surgem da interação dos componentes como um todo, não podem ser obtidas pela soma das partes isoladas.
- c) Porque os componentes individuais devem ser testados com TDD antes de integrá-los, garantindo assim a propriedade coletiva.
- d) Porque a segurança do sistema é determinada exclusivamente pelo componente mais fraco, independentemente dos demais.
- e) Porque o modelo V proíbe a especificação de requisitos de segurança em nível de subsistema.

8. [Engenharia de Sistemas — Modelo V]

Sobre o modelo de ciclo de vida V (V-Model) na engenharia de sistemas, assinale a afirmação CORRETA:

- a) As fases do modelo V são estritamente sequenciais e lineares; nenhuma atividade pode ocorrer em paralelo com outra.
- b) O modelo V é exclusivo para desenvolvimento de software e não se aplica a sistemas que incluem hardware ou componentes humanos.
- c) O modelo V é uma diretriz que pode ser customizada; muitas atividades ocorrem em paralelo e os testes permeiam todo o ciclo de vida, não apenas a fase final.
- d) No modelo V, a documentação só é iniciada após a fase de construção do sistema, para refletir o que foi efetivamente implementado.
- e) O modelo V determina que requisitos sejam coletados apenas na fase de concepção e congelados antes do início do design.

9. [Engenharia de Sistemas — Hierarquia de Documentos]

Em um projeto de sistema hospitalar complexo, após identificar as necessidades do negócio, a equipe transforma essas necessidades em requisitos formais dos usuários e operadores do sistema. Qual documento é produzido nessa etapa?

- a) BRS — Business Requirements Specification (Especificação de Requisitos de Negócio).
- b) StRS — Stakeholder Requirements Specification (Especificação de Requisitos dos Stakeholders).
- c) SyRS — System Requirements Specification (Especificação de Requisitos do Sistema).
- d) SRS — Software Requirements Specification (Especificação de Requisitos de Software).
- e) Project Charter (Carta do Projeto).

10. [Engenharia de Sistemas — Capability Gap e Design Conceitual]

Uma empresa de logística percebe que deseja rastrear cargas em tempo real, mas atualmente só consegue atualizar o status manualmente a cada 24 horas. Qual conceito da engenharia de sistemas descreve essa situação e qual fase do ciclo de vida é iniciada a partir dela?

- a) Requisito derivado; fase de design detalhado.
- b) Propriedade emergente; fase de testes de aceitação.
- c) Capability gap (lacuna de capacidade); início da fase de design conceitual.
- d) Scope matching; fase de validação e verificação.
- e) Requirements scrubbing; fase de especificação de requisitos.

11. [Engenharia de Sistemas — Rastreabilidade]

Em um projeto de sistema de defesa com milhares de requisitos, o gerente de engenharia instrui a equipe: "toda decisão de design deve ser rastreável até o requisito que a originou, e todo requisito deve ter ao menos um artefato de design ou teste associado". Que problema essa prática busca EVITAR?

- a) Scope creep apenas: impede que novos requisitos sejam adicionados sem aprovação.
- b) Requisitos ambíguos: garante que cada requisito tenha apenas uma interpretação possível.
- c) Tanto a implementação de funcionalidades sem requisito associado (gold plating / scope creep) quanto a perda de impacto de alterações nos artefatos derivados.
- d) Falhas de execução de ações de controle na estrutura de controle hierárquica.
- e) Conflitos entre requisitos funcionais e não funcionais no momento do design.

12. [STAMP — Modelo de Causalidade]

O modelo STAMP (Systems-Theoretic Accident Model and Processes) difere dos modelos tradicionais de análise de acidentes baseados em confiabilidade porque:

- a) Considera apenas falhas de hardware como causas de acidentes, excluindo erros humanos e organizacionais.
- b) Trata safety como um problema de controle, reconhecendo que acidentes podem ocorrer mesmo sem falha de componentes individuais, devido a interações inseguras no sistema.
- c) Foca exclusivamente em sistemas de software, não sendo aplicável a sistemas sociotécnicos que envolvem humanos.
- d) Quantifica probabilidades de falha com base em dados históricos de confiabilidade estatística dos componentes.
- e) É aplicável apenas à análise retrospectiva de acidentes já ocorridos, não servindo para análise preventiva.

13. [STPA — Passo 1 / Perdas e Hazards]

Para um sistema de veículo autônomo, um analista lista: (I) colisão com pedestre, (II) falha do sensor LiDAR, (III) veículo trafegando muito próximo de obstáculos. Classifique CORRETAMENTE cada item como Perda, Causa ou Hazard:

- a) I = Hazard, II = Perda, III = Causa.
- b) I = Perda, II = Hazard, III = Causa.
- c) I = Perda, II = Causa, III = Hazard.
- d) I = Causa, II = Hazard, III = Perda.
- e) I = Hazard, II = Causa, III = Perda.

14. [STPA — Passo 1 / Restrições de Sistema]

Dado o hazard H3: "o veículo autônomo não mantém distância segura de pedestres em áreas urbanas", qual das alternativas representa a restrição de segurança em nível de sistema MAIS adequada?

- a) "Instalar sensores ultrassônicos de curto alcance em todas as rodas do veículo."
- b) "O veículo deve manter distância mínima de segurança de pedestres em áreas urbanas em todas as condições operacionais."
- c) "O sistema de frenagem deve ser substituído caso apresente taxa de falha superior a 0,001 por hora."
- d) "O motorista de segurança deve assumir controle manual sempre que o sensor LiDAR indicar obstrução."
- e) "O algoritmo de visão computacional deve ser treinado com 10.000 imagens de pedestres antes da homologação."

15. [STPA — Passo 2 / Estrutura de Controle]

Ao modelar a estrutura de controle de um sistema de metrô automatizado, o analista percebe que o "Centro de Controle Operacional" envia ordens para o "Sistema Embarcado do Trem", e este, por sua vez, comanda os "Freios Físicos". Qual afirmação sobre essa estrutura é CORRETA?

- a) O Sistema Embarcado do Trem é exclusivamente um controlador, pois emite comandos para os Freios Físicos.
- b) O Sistema Embarcado do Trem é simultaneamente controlador (em relação aos Freios Físicos) e processo controlado (em relação ao Centro de Controle), dependendo do ponto de vista.
- c) Os Freios Físicos devem ser incluídos como controladores, pois geram feedback de velocidade para o Centro de Controle.
- d) A estrutura de controle modela conexões físicas entre os componentes, portanto cada seta representa um cabo ou canal de comunicação físico.
- e) O Centro de Controle só pode exercer controle se houver obediência garantida do Sistema Embarcado; caso contrário, a análise é inválida.

16. [STPA — Passo 3 / UCAs]

Em um sistema de irrigação automatizada, a válvula de irrigação recebe o comando "abrir" do controlador central. Identifique qual das situações abaixo NÃO é uma Ação de Controle Insegura (UCA):

- a) O comando "abrir" não é enviado quando o solo está extremamente seco e as plantas estão murchando.
- b) O comando "abrir" é enviado durante uma tempestade com chuva intensa, causando encharcamento.
- c) O comando "abrir" é enviado no momento correto, o solo estava seco, e a válvula responde adequadamente, iniciando a irrigação.
- d) O comando "abrir" é enviado por apenas 10 segundos quando o necessário seriam 30 minutos de irrigação.
- e) O comando "abrir" é enviado antes do sistema de filtragem estar ativo, introduzindo impurezas no sistema.

17. [STPA — Passo 4 / Cenários e Falhas de Execução]

Um controlador de tráfego aéreo emite corretamente o comando "descida autorizada" para uma aeronave, mas o piloto automático não executa a manobra porque seu sensor altimétrico está com defeito e indica altitude incorreta. Como esse cenário é classificado na STPA?

- a) Ação de controle insegura do tipo "não fornecida", pois o piloto automático não agiu conforme o esperado.
- b) Falha de execução: a control action foi emitida corretamente, mas não foi implementada de forma eficaz no processo controlado devido a falha de sensor.
- c) Modelo de processo inadequado do controlador de tráfego aéreo, que enviou um comando sem verificar a altitude real.
- d) Hazard em nível de sistema, pois a aeronave pode colidir com outro objeto.
- e) Perda inaceitável, pois representa diretamente um ferimento ou morte de passageiros.

18. [Conceitos Integrados — Sistema e Limite]

Para analisar um sistema de usina hidrelétrica com STPA, a equipe precisa definir o limite (boundary) do sistema. Quais dos itens abaixo devem ser considerados DENTRO do sistema (e não no ambiente)?

- a) O volume de chuvas na região e a velocidade das correntes do rio.
- b) A demanda de energia elétrica da população e as tarifas regulatórias.
- c) Os controladores de abertura das comportas, os sensores de nível do reservatório e os operadores humanos que monitoram o painel de controle.
- d) A direção do vento na região e a temperatura ambiente.
- e) As decisões do governo sobre expansão da matriz energética.

19. [Security na STPA / Modelos de Controle]

Um engenheiro de security propõe incluir na análise STPA de um sistema de controle industrial um cenário em que um agente externo falsifica o sinal de feedback do sensor de temperatura (spoofing), fazendo o controlador acreditar que o reator está frio quando está superaquecendo.

Essa abordagem é:

- a) Incorreta, pois a STPA foi criada exclusivamente para análise de safety e não permite a inclusão de agentes maliciosos.
- b) Incorreta, pois spoofing é tratado exclusivamente por normas de cybersecurity como IEC 62443, fora do escopo do STPA.
- c) Correta, pois a STPA pode ser estendida para security, incluindo cenários com adversários que induzem modelos de processo inadequados, levando a UCAs.
- d) Parcialmente correta, mas somente se o agente malicioso for interno à organização.
- e) Correta apenas se o sistema já estiver em operação; durante o desenvolvimento, cenários de adversários não se aplicam.

20. [Conceitos Integrados — Processo e Iteratividade]

Uma empresa inicia a análise STPA de um sistema de drones de entrega. Na primeira iteração do Passo 1, a equipe identifica apenas 4 perdas e 6 hazards. Ao avançar para o Passo 2 (estrutura de controle), percebe que há um hazard adicional não considerado inicialmente. Como a equipe deve proceder?

- a) Descartar toda a análise e reiniciá-la do zero, pois a STPA exige completude total antes de avançar de passo.
 - b) Ignorar o novo hazard nesta iteração e incluí-lo apenas na próxima versão do documento de análise.
 - c) Retornar ao Passo 1 e atualizar a lista de hazards e restrições, pois a STPA é uma técnica iterativa que permite e espera esse tipo de refinamento.
 - d) Transferir o novo hazard diretamente para o Passo 3 como UCA, sem necessidade de atualizar o Passo 1.
 - e) Suspender a análise até que um especialista externo valide se o novo hazard é realmente relevante para o sistema.
-

GABARITO COMENTADO

1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20
B	B	C	C	C	C	B	C	B	C	C	B	C	B	B	C	B	C	C	C

Questão 1 — Resposta: B | SWEBOK — Fundamentos

Elicitação é a atividade inicial de coleta/descoberta de requisitos. Usa técnicas como entrevistas, brainstorming, workshops, prototipagem e observação, com o objetivo de minimizar incompletude. Não confundir com especificação (documentação) nem com validação.

Questão 2 — Resposta: B | SWEBOK — Categorias de Requisitos

Pelo filtro da tecnologia perfeita: tudo que ainda precisa ser especificado mesmo com máquina ideal = requisito funcional. "Médico sem CRM não prescreve" é regra de negócio pura, independente de tecnologia.

Questão 3 — Resposta: C | SWEBOK — Análise e Qualidade

Resolução de conflitos é subtópico da análise de requisitos. Envolve negociação entre stakeholders e, quando há variabilidade estrutural, técnicas como Product Family Development (requisitos variantes × invariantes).

Questão 4 — Resposta: C | SWEBOK — Especificação / BDD

A estrutura Given/When/Then é a sintaxe Gherkin, base do BDD. Diferente do TDD (nível unitário) e da linguagem Z (formal matemática). O BDD produz critérios de aceitação automatizáveis via frameworks como Cucumber.

Questão 5 — Resposta: C | SWEBOK — Gestão / Rastreabilidade

Rastreabilidade forward (req → design/código/teste) e backward (código → req) é o mecanismo que permite análise de impacto. Sem rastreabilidade, alterações em requisitos podem gerar inconsistências não detectadas.

Questão 6 — Resposta: C | SWEBOK — Validação

Verificação = "construir certo a coisa" (conforme a especificação). Validação = "construir a coisa certa" (atende as reais necessidades dos stakeholders). Conceito atribuído a Barry Boehm.

Questão 7 — Resposta: B | Engenharia de Sistemas — Propriedades Emergentes

Safety e security são propriedades emergentes: surgem exclusivamente da interação dos componentes integrados. O todo é maior que a soma das partes — analisar componentes isolados não captura essas propriedades.

Questão 8 — Resposta: C | Engenharia de Sistemas — Modelo V

O modelo V é uma diretriz (não uma receita rígida), instanciada para cada projeto. As atividades ocorrem em paralelo; testes e requisitos são produzidos ao longo de todo o ciclo. A aparência sequencial da figura é apenas pedagógica.

Questão 9 — Resposta: B | Engenharia de Sistemas — Hierarquia de Documentos

A hierarquia é: BRS (necessidades de negócio) → StRS (requisitos dos stakeholders) → SyRS (requisitos do sistema) → Sub-SyRS (subsistemas). A etapa descrita transforma necessidades operacionais em requisitos formais dos stakeholders, gerando o StRS.

Questão 10 — Resposta: C | Engenharia de Sistemas — Capability Gap e Design Conceitual

Capability gap = diferença entre a capacidade atual (atualização 24h) e a capacidade desejada (rastreamento em tempo real). Quando um gap crítico é identificado e priorizado, inicia-se o design conceitual.

Questão 11 — Resposta: C | Engenharia de Sistemas — Rastreabilidade

A rastreabilidade forward+backward evita: (1) código sem requisito (gold plating / scope creep); (2) requisitos sem implementação; (3) alterações cujo impacto nos artefatos derivados não é identificado. É essencial em sistemas complexos.

Questão 12 — Resposta: B | STAMP — Modelo de Causalidade

STAMP = safety como problema de controle. Acidentes podem ocorrer sem que nenhum componente individualmente falhe — emergem de interações inseguras. Contrasta com abordagens baseadas em confiabilidade (cadeia de falhas).

Questão 13 — Resposta: C | STPA — Passo 1 / Perdas e Hazards

Perda (I): resultado inaceitável para stakeholders (colisão = ferimento/morte). Causa (II): falha de componente que pode levar a um hazard (falha do LiDAR). Hazard (III): estado do sistema que, em pior caso ambiental, leva à perda (veículo próximo demais de obstáculos = condição controlável pelo projetista).

Questão 14 — Resposta: B | STPA — Passo 1 / Restrições de Sistema

Restrições de sistema são derivadas negando o hazard, em alto nível, sem prescrever solução específica. A alternativa b nega H3 corretamente. As alternativas a, c, d e e prescrevem soluções/implementações específicas, o que é feito em passos posteriores da análise.

Questão 15 — Resposta: B | STPA — Passo 2 / Estrutura de Controle

Na estrutura de controle hierárquica, um mesmo componente pode ser controlador de um nível abaixo e processo controlado de um nível acima simultaneamente. A estrutura é funcional (não física) e não pressupõe obediência.

Questão 16 — Resposta: C | STPA — Passo 3 / UCAs

A alternativa c descreve uma situação ideal: comando correto, no momento certo, com duração adequada, executado corretamente. Isso é o oposto de UCA. As demais são UCAs: (a) não fornecida quando necessária, (b) fornecida quando não devia, (d) duração inadequada, (e) momento/ordem inadequados.

Questão 17 — Resposta: B | STPA — Passo 4 / Cenários e Falhas de Execução

Falha de execução (Passo 4): a control action foi segura e corretamente enviada, mas o processo controlado não a implementou adequadamente. Aqui, o defeito do sensor altimétrico impede a execução — tipicamente identificado no Passo 4, não no Passo 3 (UCAs).

Questão 18 — Resposta: C | Conceitos Integrados — Sistema e Limite

O limite do sistema inclui componentes sob controle dos projetistas/operadores. Comportas, sensores e operadores humanos são partes do sistema controlável. Chuvas, vento, demanda externa e decisões governamentais são o ambiente.

Questão 19 — Resposta: C | Security na STPA / Modelos de Controle

A STPA pode ser aplicada para qualquer propriedade emergente, incluindo security. Cenários com adversários (spoofing, alteração de comandos) são incluídos para modelar como ataques induzem modelos de processo incorretos → UCAs → perdas.

Questão 20 — Resposta: C | Conceitos Integrados — Processo e Iteratividade

A STPA é iterativa e incremental. É comum e esperado que novos hazards, perdas ou restrições sejam descobertos em passos posteriores. A equipe deve retornar ao Passo 1 e atualizar os artefatos, mantendo rastreabilidade.